

CO4 – AT2 Industry Problem-Solving Task

Course: Cryptography and Network Security

Course Code: CSA5104

Course Outcome: CO4

NAME:RAJASHREE S

REG NO:192521079

1. IPSec Security for Branch Offices

A multinational enterprise uses IPSec to secure communication between branch offices over the public Internet. IPSec provides authentication, integrity, confidentiality, and protection against attacks.

A. Identify which traffic requires AH, ESP, or both

Authentication Header (AH):

- Provides authentication and data integrity.
- Protects against modification and spoofing.
- Does **not provide encryption/confidentiality**.
- Suitable for traffic where confidentiality is not required.

Encapsulating Security Payload (ESP):

- Provides confidentiality through encryption.
- Also provides integrity and authentication.
- Suitable for sensitive business information such as financial data, employee information, and confidential files.

AH + ESP:

- Can be used when both strong authentication/integrity and confidentiality are required.
- However, in most modern deployments, **ESP with authentication/integrity is preferred** because it provides both functions efficiently.

B. Packet flow and IPSec modes

Tunnel Mode:

Branch A → Encrypt & Authenticate → Internet → Decrypt & Verify → Branch B

Tunnel mode encrypts the complete original IP packet and adds a new IP header. It is mainly suitable for **branch-to-branch VPN communication**.

Transport Mode:

Original IP Header + ESP/AH + Data

Transport mode protects the payload while keeping the original IP header. It is generally suitable for **host-to-host communication**.

C. Justification

For confidential company information, **ESP tunnel mode** is recommended because it provides encryption, integrity, and authentication. AH is useful when data integrity and authentication are needed without encryption.

D. Performance vs. security trade-off

Method	Security	Performance
AH	Integrity + Authentication	Faster
ESP	Confidentiality + Integrity + Authentication	Moderate
AH+ESP	Maximum protection	Higher overhead

Conclusion: For enterprise branch communication, **ESP in tunnel mode** is the preferred solution because it provides strong security with reasonable performance. The assessment specifically asks for AH/ESP selection, IPSec modes, protocol justification, and performance/security evaluation.

2. IPSec Security Association and Key Management

The organization faces expired and mismatched keys. This can cause communication failures and security risks. An automated key-management system should therefore be implemented.

A. Current SA lifecycle issues

Security Associations (SAs) may fail because of:

- Expired encryption keys.
- Different keys configured on two endpoints.
- Incorrect Security Parameter Index (SPI).
- Manual key configuration errors.
- Failure to renew keys on time.
- Lack of centralized monitoring.

These problems can interrupt communication between branches.

B. Automated key management using IKE

The organization should use **Internet Key Exchange (IKE)** to automate authentication and key establishment.

Basic process:

Initiator → IKE Negotiation → Authentication → Key Exchange → SA Creation → Secure IPSec Communication

IKE automatically negotiates security parameters and establishes shared keys instead of requiring administrators to configure keys manually.

C. Key renewal and revocation

The system should:

1. Set a lifetime for every SA.
2. Renew keys automatically before expiration.
3. Use new keys for future sessions.

4. Immediately revoke compromised credentials.
5. Monitor SA status centrally.
6. Maintain logs for key creation, renewal, and revocation.

D. Scalability and fault tolerance

For a large enterprise:

- Use centralized configuration and monitoring.
- Deploy redundant VPN gateways.
- Use automatic IKE-based negotiation.
- Maintain backup authentication systems.
- Monitor failed or expired SAs.
- Use load balancing where required.

Conclusion: Automated IKE-based key management reduces manual errors, prevents expired-key problems, and provides scalable and fault-tolerant IPSec communication. These requirements directly match the assignment's SA lifecycle, automated key exchange, renewal/revocation, scalability, and fault-tolerance tasks.

3. PGP vs S/MIME for Secure Email

A financial services company needs secure email for sensitive transactions. Both **PGP** and **S/MIME** provide encryption and digital signatures, but their trust and management models differ.

A. Comparison of PGP and S/MIME

Feature	PGP	S/MIME
Encryption	Yes	Yes
Digital Signature	Yes	Yes
Trust Model	Decentralized/Web of Trust	Certificate Authority (CA)
Enterprise Management	More difficult	Easier
Certificate Management	User-managed keys	CA-managed certificates
Enterprise Integration	Moderate	High
Scalability	More difficult	Better

B. Key management and trust models

PGP:

- Uses a decentralized trust model.
- Users exchange and verify public keys.
- Suitable for individuals and smaller communities.
- Key management can become difficult in large organizations.

S/MIME:

- Uses digital certificates issued by trusted Certificate Authorities.
- Organizations can centrally manage certificates.
- Easier to integrate with enterprise email systems.

C. Recommendation

For a **financial services company**, **S/MIME is recommended** because it provides:

- Centralized certificate management.
- Strong authentication.
- Digital signatures.
- Encryption.
- Better enterprise integration.
- Easier administration for large numbers of employees.

D. High-level implementation workflow

Create CA → Issue Certificates → Install Certificates → Configure Email Client → Send Signed Email → Encrypt Sensitive Email → Recipient Validates Certificate → Decrypt Message

Conclusion: Although PGP is effective and flexible, S/MIME is more appropriate for a large financial organization because of its centralized trust model, certificate management, scalability, and enterprise integration. The assignment specifically requires comparison, trust/key management analysis, recommendation, and implementation workflow.

4. Advanced Spam and Phishing Detection

The company is experiencing increasing phishing and spam attacks even though basic filtering is enabled. Basic filters may fail because attackers continuously change email content and sender information.

A. Limitations of existing filtering

Basic filtering may have the following weaknesses:

- Reliance on simple keywords.
- Limited analysis of sender information.
- Difficulty detecting new phishing attacks.
- Attackers can modify email content to bypass filters.
- Cannot effectively identify sophisticated spoofing.
- May generate false positives.

B. Email header analysis

Important header information includes:

- **From:** Checks the displayed sender.
- **Reply-To:** Identifies where replies are actually directed.
- **Received:** Shows the path followed by the email.
- **Return-Path:** Helps identify the actual return address.
- **SPF:** Checks whether the sending server is authorized.
- **DKIM:** Verifies message integrity and domain authentication.
- **DMARC:** Helps detect spoofing and defines domain-level email policies.

Suspicious differences between sender addresses, authentication results, and mail-server paths can indicate phishing.

C. Improved detection model

A **hybrid rule-based + machine-learning model** can be used.

Step 1: Collect email headers and content.

Step 2: Check authentication results such as SPF, DKIM, and DMARC.

Step 3: Analyze:

- Sender reputation.
- URLs.
- Keywords.
- Attachments.
- Email structure.
- Header anomalies.

Step 4: Use a machine-learning classifier to calculate the probability of spam/phishing.

Step 5: Classify emails as:

Safe → Suspicious → Spam/Phishing

D. Effectiveness and false-positive handling

The system should be evaluated using:

- Accuracy.
- Precision.
- Recall.
- False-positive rate.
- False-negative rate.

Emails with uncertain scores can be placed in a **quarantine folder** instead of being permanently deleted. Users or administrators can review them and provide feedback to improve the detection model.

Conclusion: A hybrid system combining header authentication, content analysis, sender reputation, and machine learning can provide stronger protection than basic filtering. The assessment asks specifically for existing-filter limitations, header spoofing analysis, improved detection, and false-positive evaluation.

5. S/MIME Certificate Management

During a security audit, encrypted emails are found to be vulnerable because certificates are not handled correctly. Poor certificate management can allow attackers to impersonate users or cause encrypted communication to fail.

A. Certificate-related vulnerabilities

Possible problems include:

- Expired certificates.
- Revoked certificates still being trusted.
- Invalid certificates.
- Self-signed certificates being trusted without proper verification.
- Private keys being exposed.
- Incorrect certificate installation.
- Weak certificate protection.
- Failure to check certificate validity.

B. Trust chain and validation

An S/MIME certificate should be validated through a trusted certificate chain:

Root CA → Intermediate CA → User Certificate

The email client should verify:

1. Certificate issuer.
2. Certificate validity period.
3. Digital signature.
4. Certificate chain.
5. Revocation status.
6. Certificate identity.
7. Intended usage.

If validation fails, the certificate should not be automatically trusted.

C. Secure certificate storage and management

The organization should:

- Store private keys securely.
- Protect private keys using strong passwords or hardware-backed security where appropriate.
- Restrict access to certificates and private keys.
- Maintain a centralized certificate inventory.
- Monitor certificate expiration.

- Renew certificates before expiry.
- Revoke compromised certificates immediately.
- Maintain secure backups.

D. User awareness and system configuration

Users should be trained to:

- Check certificate warnings.
- Avoid blindly trusting unknown certificates.
- Report suspicious certificate messages.
- Protect their private keys.
- Never share private keys.

System administrators should configure email clients to perform proper certificate-chain and revocation validation.